SECCIÓN 6.4

Preservación de evidencia y manejo seguro del entorno

Temas de esta sección:

- Preservar, contener y remediar: tres conceptos distintos y en orden
- Qué evidencia guardar según el tipo de caso (endpoint, identidad, red, web)
- Qué puede perderse al reiniciar, borrar, aislar o eliminar reglas
- Evidencia volátil: procesos en ejecución, conexiones activas, memoria
- Checklist de preservación rápida antes de contener
- Cuándo la contención puede ir antes que la preservación

En respuesta inicial, muchas veces primero preservamos, luego contenemos y después remediamos. Saltear el orden genera problemas.

PRESERVAR	Guardar información necesaria para entender lo ocurrido.	*Exportar logs · Registrar hash · Guardar command line · Documentar timestamps · Capturar detalles de alerta · Registrar reglas/tokens*
CONTENER	Reducir la capacidad de la amenaza de seguir actuando.	*Aislar endpoint · Bloquear dominio · Revocar sesiones · Deshabilitar usuario · Aplicar regla WAF*
REMEDIAR	Eliminar causa, artefactos o debilidades asociadas.	*Eliminar malware · Cerrar vulnerabilidad · Corregir configuración · Resetear credenciales · Aplicar parche*

Excepción: si el impacto es activo y creciente (ransomware en curso), puede contenerse primero y completar preservación después — documentando qué se perdió.

La evidencia prioritaria varía según dónde ocurrió el posible incidente:

ENDPOINT

- Alerta y detalles del evento
- Process tree completo
- Command line exacta
- Hash SHA256 del archivo
- Ruta completa y firma
- Tarea programada creada
- Run Key o servicio
- IPs/dominios de conexión
- Otros hosts con mismo indicador
- Timestamps de cada acción

IDENTIDAD / CUENTA

- Login original: IP, hora, dispositivo
- Resultado MFA
- Dispositivo nuevo o conocido
- Nombre y destino de regla de correo
- App OAuth: nombre, permisos, timestamp
- Archivos descargados (count/tipo)
- Sesiones activas y tokens vigentes
- Nuevos métodos MFA agregados
- Apps con acceso otorgado

RED / WEB

- IP destino y dominio
- Puerto y protocolo
- Acción del control
- Proceso que generó la conexión
- Frecuencia y volumen
- Requests HTTP (WAF logs)
- Payload y respuesta HTTP
- Archivo creado en servidor
- Proceso hijo del web server
- IP origen del atacante

Acciones de respuesta comunes que pueden destruir evidencia si no se hace primero el registro:

REINICIAR EQUIPO	Puede perderse: Procesos activos · Conexiones · Contenido en memoria · Relación de procesos hijos · Archivos temporales · Estado del malware	Antes: Registrar procesos, command lines y conexiones activas.
BORRAR ARCHIVO SOSPECHOSO	Puede perderse: Hash · Firma · Tamaño · Timestamps · Muestra para análisis · Confirmación de familia · Relación con otros hosts	Antes: Obtener hash, ruta, timestamps y firma. Preservar muestra si el procedimiento lo permite.
ELIMINAR REGLA DE CORREO	Puede perderse: Destinatario externo · Condiciones de la regla · Timestamp · Sesión/IP asociada · Evidencia de persistencia	Antes: Registrar nombre, destino, condiciones, timestamp y sesión asociada.
AISLAR ENDPOINT	Puede perderse: Conexiones activas · Acceso remoto para análisis · Recolección automática de evidencia	Antes: Validar playbook, registrar evidencia mínima y comunicar si corresponde.
REVOCAR SESIONES/TOKENS	Puede perderse: IPs de sesión activa · Dispositivos conectados · Aplicaciones afectadas · Tokens con permisos	Antes: Registrar IPs, dispositivos, timestamps y apps antes de revocar.

6.4 | Evidencia volátil: qué desaparece primero

La evidencia volátil existe solo mientras el sistema está encendido y activo. Es la más crítica y la que más se pierde:

Procesos en ejecución	Lista completa de procesos activos, PIDs, process tree, command lines, usuarios que los ejecutan. Desaparece al reiniciar o matar el proceso.	*EDR o EDR snapshot. tasklist /v · ps aux.*
Conexiones de red activas	Sockets abiertos, IPs conectadas, puertos en escucha, PID asociado. Cambia continuamente y se pierde al reiniciar o al aislar el host.	*netstat -ano · ss -tulnp · EDR network view.*
Contenido en memoria (RAM)	Código en ejecución, claves de cifrado, credenciales en memoria, payloads fileless. Imposible recuperar sin un memory dump.	*Memory dump con herramienta forense. Requiere IR.*
Tokens y sesiones activas	Tokens de autenticación, sesiones abiertas, credenciales cacheadas. Se pierden al revocar sesión o reiniciar el servicio de autenticación.	*Registrar tokens activos en identidad antes de revocar.*
Archivos temporales y logs circulares	Archivos en %TEMP%, logs que rotan, archivos de paginación. Pueden contener evidencia de actividad reciente que se sobrescribe.	*Exportar logs del SIEM y EDR antes de cualquier acción.*

6.4 | Checklist de preservación rápida

Antes de contener, cuando el tiempo lo permite, verificar:

- [ ] ¿Tengo la alerta original?
- [ ] ¿Tengo usuario y host?
- [ ] ¿Tengo archivo, ruta y hash?
- [ ] ¿Tengo la acción del control?
- [ ] ¿Tengo alcance inicial (otros hosts)?
- [ ] ¿Documenté limitaciones de visibilidad?
- [ ] ¿Tengo timestamps exactos?
- [ ] ¿Tengo proceso y command line completa?
- [ ] ¿Tengo dominio/IP de conexión?
- [ ] ¿Tengo actividad previa y posterior?
- [ ] ¿Registré acciones tomadas?
- [ ] ¿Hay reglas, tokens u OAuth apps para registrar?

Este checklist no reemplaza un proceso formal de IR. En casos de alto impacto con amenaza activa, puede contenerse primero — pero documentar qué evidencia pudo haberse perdido y por qué se actuó rápido.

6.4 | Cuándo la contención puede ir antes que la preservación

La regla general es preservar primero. Pero hay situaciones donde el riesgo de esperar supera el valor de la evidencia:

Contener PRIMERO (alta urgencia)	Preservar PRIMERO (situación controlable)
▸ Ransomware activo cifrando archivos en tiempo real	▸ Malware detectado pero ya bloqueado por el EDR
▸ Wiper destruyendo datos en servidores críticos	▸ Conexión sospechosa pero el proceso no está activo
▸ Exfiltración masiva de datos en curso (tráfico saliente activo)	▸ Regla de correo creada pero sin exfiltración confirmada
▸ Movimiento lateral activo hacia controladores de dominio	▸ Web shell detectado en servidor no productivo
▸ Atacante con acceso interactivo y ejecutando comandos	▸ Login anómalo sin actividad posterior en los últimos 30 min

Cuando se contiene antes de preservar: documentar inmediatamente qué evidencia pudo haberse perdido y justificar por qué se priorizó la contención.